



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI

BSI TR-03187

Sicherheitsanforderungen an Urbane Datenplattformen



Änderungshistorie

<i>Version</i>	<i>Datum</i>	<i>Name</i>	<i>Beschreibung</i>
1.0	20.02.2025	BSI	Erstellung Version 1.0

Tabelle 1: Änderungshistorie

Inhalt

1	Einleitung	4
2	Begriffsdefinition und Modell	5
2.1	Definitionen	5
2.2	Generisches Modell einer UDP	6
3	Anforderungen	8
3.1	Architektur	9
3.1.1	Container-Technologie	13
3.1.2	Managed-Service	16
3.2	Authentifizierung und Autorisierung (AuthN/Z)	18
3.3	Schnittstellen	19
3.3.1	Web-Anwendungen und Web-Schnittstellen	19
3.3.2	IoT-Anbindungen	23
3.3.3	VPN-Zugang	25
3.4	Logging	26
3.5	Datenhaltung	27
3.6	IT-Sicherheitsorganisation	28
4	Anwendungsbeispiel	31
4.1	Plattformkomponenten	32
4.2	Externe Schnittstellen	33
5	Abkürzungsverzeichnis	34

1 Einleitung

Die fortschreitende Digitalisierung von Städten und Kommunen umfasst nicht nur die klassischen Verwaltungsdienste, sondern zunehmend auch kommunale Infrastrukturen zur Daseinsvorsorge, wie zum Beispiel das Verkehrswegenetz und verbundene Beförderungsmöglichkeiten, Wasser- und Energieversorgung oder Müll- und Abwasserbeseitigung. Mit der Vernetzung von kommunalen Infrastrukturen werden immer mehr Systeme, Dienste, Geräte und Gegenstände mit Kommunikationsschnittstellen ausgestattet und so Teil eines kontinuierlich wachsenden öffentlichen Datenraums. In diesem Zusammenhang wird der Begriff der Smart City bzw. Smart Region verwendet, der beschreibt, dass intelligente Informations- und Kommunikationstechnologie (IKT) verwendet wird, um Teilhabe und Lebensqualität zu erhöhen und eine ökonomisch, ökologisch und sozial nachhaltige Stadt oder Region zu schaffen.

Ein häufiger Anwendungsfall einer solchen umfassenden Vernetzung ist die Möglichkeit, dezentral von zahlreichen Systemen und Sensoren Daten mit verschiedenen Inhalten und in verschiedenen Formaten zu sammeln, zusammenzuführen und zu verarbeiten. Auf dieser Basis können Entscheidungen getroffen, Prozesse (ggf. automatisiert) gesteuert und Daten für weitere Systeme bereitgestellt werden. Eine Plattform, die einen oder mehrere der genannten Anwendungsfälle realisiert, wird auch als Urbane Datenplattform (UDP) bezeichnet. Immer mehr Städte und Kommunen befassen sich gerade mit dem Aufbau einer solchen UDP oder haben sogar schon mit dem Betrieb gestartet. Datenplattformen, deren primärer Zweck die öffentliche Bereitstellung von Daten ist, werden häufig auch als Open Data Platforms bezeichnet.

Die Absicherung eines solchen Systems stellt eine große Herausforderung dar. Hier werden nicht nur Daten aus einer Vielzahl von Quellen und über eine Vielzahl von Protokollen übertragen, die sicher entgegengenommen, authentifiziert und verarbeitet werden müssen, sondern die UDP kann selbst aus zahlreichen Microservices, virtuellen Maschinen, Datenbanken und anderen Komponenten bestehen, die jeweils für sich und in ihrer Interaktion untereinander gesichert werden müssen. Als zentrale Datensammelstelle ist die UDP ein besonders attraktives Angriffsziel. Weiterhin verfehlen IT-Sicherheitsmaßnahmen ohne flankierende organisatorische Maßnahmen häufig ihr Ziel. So führt bspw. ein fehlendes oder ineffizientes Patch-Management in der Praxis oft dazu, dass vormals technisch sichere Systeme nach dem Bekanntwerden einer Sicherheitslücke plötzlich und für lange Zeit angreifbar sind.

Im Zuge der Digitalisierung von Kommunen lässt sich auch eine Erhöhung der Angriffsaktivitäten auf kommunale IT-Infrastrukturen mit teils erheblichen Schäden beobachten. Damit die Angriffsfläche für die wachsende Zahl von UDPs bereits in einem frühen Stadium minimiert wird, wurde diese Technische Richtlinie mit dem Ziel entwickelt, die Informationssicherheit von UDPs zu erhöhen. Um dieses Ziel zu erreichen, sind Anforderungen an Betreiber, Entwickler und Lösungsanbieter formuliert worden, die in allen Phasen des Entwicklungs- und Lebenszyklus einer UDP – von der Design-Phase bis zum Betrieb – die IT-Sicherheit angemessen sicherstellen sollen. In die Entwicklung der Anforderungen sind, neben der Analyse verschiedener IT-Sicherheitsstandards, auch Ergebnisse von Schwachstellenanalysen bestehender UDPs eingeflossen. Um unterschiedlich hohen Anforderungen an die Informationssicherheit angemessen begegnen zu können, wurden die im Dokument formulierten Anforderungen – in Anlehnung an das Vorgehen der OWASP im Application Security Verification Standard¹ – in drei verschiedene Schutzlevel unterteilt. Die Schutzlevel in dieser technischen Richtlinie sind daher nicht deckungsgleich mit den Schutzniveaus des BSI-Grundschutzes. Der BSI-Grundschutz kann und sollte jedoch ergänzend zu den hier geforderten Maßnahmen angewendet werden, da dieser insbesondere auch weitere Bereiche abgedeckt, die nicht unmittelbar einer UDP zuzuordnen sind.

¹ <https://owasp.org/www-project-application-security-verification-standard/>

2 Begriffsdefinition und Modell

Als Grundlage für die Formulierung von Anforderungen der vorliegenden Technischen Richtlinie wurden wichtige Begriffe definiert und ein generisches Modell aller für eine UDP relevanten Bausteine erstellt. Dabei war das Ziel, ein möglichst offenes Modell zu entwickeln, das grundsätzlich in der Lage ist, verschiedene Anwendungsfälle für den Einsatz von UDPs abbilden zu können – von der Bereitstellung öffentlicher Statistikdaten bis zum Angebot digitaler Bürgerdienste. Ob eine einzelne UDP mit dem nachfolgend vorgestellten Modell abgebildet werden kann und in welchem Umfang die nachfolgenden Anforderungen entsprechend anwendbar sind, muss immer im Einzelfall bewertet werden.

2.1 Definitionen

Application Programming Interface (API): Schnittstelle, über die typischerweise Anwendungen miteinander kommunizieren und Daten austauschen

Authentifizierung: Vorgang der Überprüfung der Identität einer Person oder eines (Teil-)Systems

Autorisierung: Zuordnung und Überprüfung von (Zugriffs-)Rechten zu einer Person oder einem (Teil-)System

Authentisierung: Nachweis der Identität einer Person oder eines (Teil-) Systems

Baustein: technischer oder organisatorischer Aspekt, der für den sicheren Betrieb einer UDP essenziell ist

Betreiber²: diejenigen, die für die Aufrechterhaltung des Betriebs, das Deployment oder die Einrichtung der notwendigen Infrastruktur der UDP verantwortlich und/oder operativ zuständig sind

Container: Softwarekomponente, die andere Softwarekomponenten in einer vorher konfigurierten Ausführungsumgebung bündelt

Dienst: spezifische Funktionalität, die durch eine Komponente zur Verfügung gestellt wird

Entwickler²: diejenigen, die für die softwaretechnische Entwicklung einzelner oder mehrerer Komponenten der UDP verantwortlich sind

Fachlicher Administrator: Rolle, mit der Änderungen an der Konfiguration von Komponenten oder Diensten innerhalb der UDP vorgenommen werden können

Infrastruktur: physische Systeme sowie Betriebssysteme, auf denen Softwarekomponenten betrieben werden

Infrastrukturadministrator: Rolle, mit der On-Premise betriebene oder durch einen Managed-Service-Anbieter bereitgestellte Infrastruktur konfiguriert und verwaltet werden kann

IoT-Gerät: vernetztes Gerät, das in der Regel zur dezentralen Verarbeitung von Daten genutzt wird und Daten über ein Netzwerk senden und empfangen kann

Komponente: Einheit oder Verbund von Einheiten innerhalb eines IT-Systems über die ein oder mehrere Dienste angeboten werden

Lösungsanbieter²: diejenigen, die verschiedene bestehende oder eigenentwickelte Komponenten zu einer UDP integrieren und in Verkehr bringen

Managed-Infrastruktur: fremdbetriebene IT-Infrastruktur, die teils oder vollständig unter Kontrolle eines Managed-Service-Anbieters steht

² Betreiber, Entwickler und Lösungsanbieter können jeweils durch einzelne Unternehmen oder öffentliche Einrichtungen repräsentiert werden, oder durch ein Konsortium aus diesen. Es ist auch möglich, dass einzelne Organisationen mehrere oder alle der drei Rollen innehaben.

Managed-Service-Anbieter³: Anbieter von IT-Infrastruktur und darauf basierenden Diensten zur Miete, die jeweils nicht vollständig unter Kontrolle des Mieters stehen

On-Premise-Infrastruktur: selbst betriebene IT-Infrastruktur, die vollständig unter eigener Kontrolle steht

Plattformkomponente: Komponente, die Teil einer UDP ist

Registrierung: Vorgang der erstmaligen Anmeldung an einem System, bei dem auch Anmeldeinformationen persistent auf dem System abgelegt werden

Ressource: Komponente, Daten oder Dienst, auf die durch andere Komponenten oder Dienste zugegriffen werden kann

Sitzung (Session): zeitweise bestehende Verbindung eines Clients mit einem Server

Sitzungsdaten: Daten, die im Rahmen einer bestehenden Sitzung (Session) ausgetauscht werden

Softwarekomponente: eigenständige und wiederverwendbare Software-Einheit oder ein Verbund von Software-Einheiten, die Dienste ausführt und Schnittstellen bereitstellt, um mit anderen Komponenten oder Systemen zu interagieren

Urbane Datenplattform (UDP): digitale Infrastruktur einer Smart City, in der Daten aggregiert, generiert, verwaltet und ausgetauscht werden

Web-Anwendung: IT-System mit dem typischerweise über das Hypertext Transfer Protocol (HTTP) interagiert wird (bspw. durch Nutzung eines Browsers)

Zugriffskontrollmechanismus: technisches Verfahren, mit dem die Regeln eines Zugriffskontrollmodells durchgesetzt werden

Zugriffskontrollmodell: Modell, das beschreibt, welche Gruppen und Rollen welche Art des Zugriffs auf welche Kategorien von Daten erhalten sollen

2.2 Generisches Modell einer UDP

Ziel dieses generischen Modells ist es, Sicherheitsanforderungen nachvollziehbar nach Bausteinen strukturieren und Anforderungen an die Systemarchitektur festlegen zu können.

Abbildung 1 zeigt das diesem Dokument zugrundeliegende generische Modell einer UDP mit den zugehörigen relevanten Bausteinen. Dabei kann jeder dargestellte Baustein beliebig viele Plattformkomponenten enthalten, die dessen Funktion realisieren.

Folgende Bausteine sind im Modell enthalten:

- **Architektur**: Beschreibt die Struktur und das Design einer UDP, einschließlich der Organisation von Komponenten, deren Interaktion sowie plattformweite Sicherheitsmechanismen. Besondere Anforderungen gelten hier für:
 - **Container-Technologie**: Beinhaltet alle Komponenten, die auf Basis von Container-Technologien (bspw. Docker oder Podman) bzw. auf Basis der OCI-Spezifikation⁴ betrieben werden oder deren Betrieb ermöglichen.
 - **Managed-Service**: Beinhaltet alle Komponenten, die von einem Managed-Service-Anbieter betrieben werden.

³ Unter Managed-Service-Anbieter fallen explizit auch Anbieter von Hyperscalern (wie beispielsweise Amazon, Google und Microsoft).

⁴ <https://opencontainers.org>

- **AuthN/Z:** Beinhaltet alle Komponenten, die Benutzer- oder Geräteauthentifizierung oder -autorisierung vornehmen, sowie Autorisierungsinformationen an weitere Komponenten bereitstellen können.
- **Schnittstellen:** Beinhaltet alle Kommunikationsmöglichkeiten mit (externe Schnittstelle) und innerhalb (interne Schnittstelle) der Plattform.
Hierbei werden drei Kategorien unterschieden:
 - **Web-Schnittstelle:** Beinhaltet alle Komponenten, die entweder HTTP(S)-basierte Schnittstellen (bspw. REST, SOAP oder WebSockets) zur Kommunikation mit der UDP anbieten oder ganze Web-Anwendungen bereitstellen. Web-Schnittstellen können sowohl extern als auch intern sein.
 - **IoT-Schnittstelle:** Beinhaltet alle Komponenten, die für die Kommunikation mit IoT-Geräten zuständig sind. IoT-Schnittstellen sind immer externe Schnittstellen.
 - **VPN-Schnittstelle:** Beinhaltet alle Komponenten, welche die Schnittstellen zur Infrastrukturadministration bereitstellen. VPN-Schnittstellen sind immer externe Schnittstellen.
- **Logging:** Alle Komponenten, die Informationen zu Events erfassen, mit zugehörigen Zeitstempeln versehen, speichern oder zur Verarbeitung aufbereiten.
- **Datenhaltung:** Beinhaltet alle Komponenten, die für die persistente Speicherung von Daten zuständig sind.
- **IT-Sicherheitsorganisation:** Umfasst die Struktur, Rollen, Verantwortlichkeiten und Prozesse innerhalb einer Organisation, die für die Etablierung und Aufrechterhaltung der Sicherheit von Informationstechnologien und Daten verantwortlich ist.

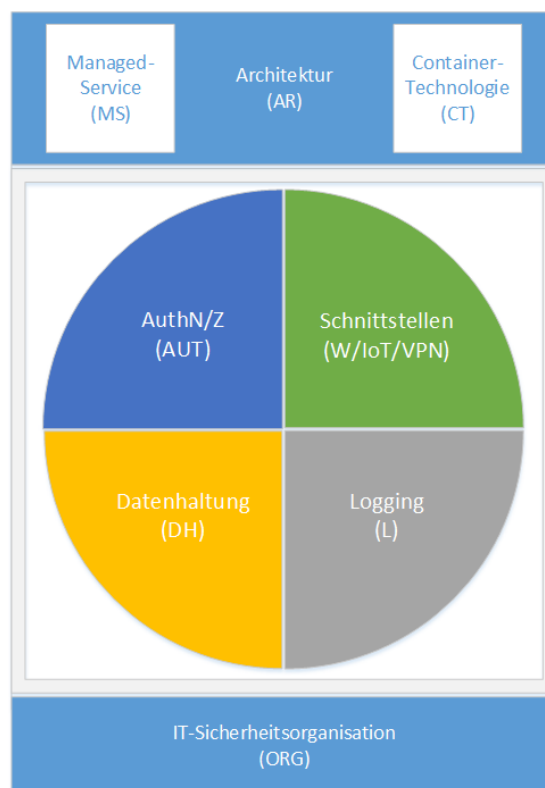


Abbildung 1: Generisches Modell einer UDP

3 Anforderungen

Im Folgenden werden technische und organisatorische Sicherheitsanforderungen an eine UDP beschrieben.

Die hier enthaltenen Sicherheitsanforderungen sind in drei Schutzlevel eingeteilt. Schutzlevel 1 fordert dabei die absoluten Mindestanforderungen, die für den sicheren Betrieb einer UDP unbedingt erforderlich sind. Schutzlevel 2 und 3 bauen darauf auf und fordern weiterführende Schutzmaßnahmen, mit denen die Gesamtsicherheit des Systems – im Sinne von „Defense in Depth“ – weiter erhöht werden kann.

Betreiber, Entwickler und Lösungsanbieter können, auf Basis einer individuellen Risikobewertung, (z. B. gemäß ISO/IEC 27005:2022, BSI Standard 200-3, OWASP Risk Rating Methodology) entscheiden, welches Schutzlevel sie mit ihrer Lösung erzielen wollen. Davon abhängig müssen alle Anforderungen bis zur gewählten Stufe inkrementell umgesetzt werden.

Die Sicherheitsanforderungen sind weiterhin nach Bausteinen gruppiert, um eine schnelle Zuordnung relevanter Anforderungen für die in der UDP eingesetzten Bausteine zu ermöglichen.

Die folgenden tabellarischen Auflistungen der Anforderungen sind so zu interpretieren, dass ein „x“ in der jeweiligen Spalte „Schutzlevel“ bedeutet, dass die Anforderung auf dem markierten Schutzlevel umgesetzt werden muss. Eine Anforderung mit Markierungen in allen drei Spalten des Schutzlevel muss somit immer umgesetzt werden – das ist bei zentralen Sicherheitsanforderungen der Fall. Eine Anforderung, bei der nur „Schutzlevel 3“ markiert ist, muss erst für Schutzlevel 3 umgesetzt werden – das ist bei sehr fortgeschrittenen Defense-in-Depth-Maßnahmen der Fall.

In der Spalte „Anwendbar für“ ist angegeben, für welche Adressaten dieser Technischen Richtlinie diese Anforderung relevant ist, bzw. von welchen dieser Adressaten die Anforderung typischerweise umgesetzt wird. Dabei ist zu berücksichtigen, dass gerade in komplexen Konsortialverbünden eine scharfe Trennung der Adressaten nicht immer einfach möglich ist, sodass die Prüfung, in welcher Rolle sich ein Anwender dieser technischen Richtlinie in einem konkreten Anwendungsfall jeweils befindet, immer individuell vorgenommen werden muss.

Die folgenden Schlüsselwörter werden bei der Definition der Anforderungen verwendet:

- **MUSS/MÜSSEN:** Die Anforderung muss unbedingt erfüllt werden, wenn das markierte Schutzlevel erreicht werden soll.
- **DARF/DÜRFEN NICHT:** Der in der Anforderung beschriebene Sachverhalt darf unter keinen Umständen realisiert sein, wenn das markierte Schutzlevel erreicht werden soll.
- **SOLL/SOLLEN:** Die Anforderung muss erfüllt werden, wenn das markierte Schutzlevel erreicht werden soll, es sei denn der Umsetzung stehen wesentliche technische Gründe entgegen. Diese Gründe müssen dann nachvollziehbar dargelegt werden.
- **SOLL/SOLLEN NICHT:** Der in der Anforderung beschriebene Sachverhalt darf nicht realisiert sein, wenn das markierte Schutzlevel erreicht werden soll, es sei denn, dem stehen wesentliche technische Gründe entgegen. Diese Gründe müssen dann nachvollziehbar dargelegt werden.

Innerhalb der Anforderungen werden Beispiele verwendet, um die Anforderungen greifbarer und praxisnäher zu gestalten. Hierbei wird zwischen zwei verschiedenen Arten von Beispielen unterschieden, die hier näher erläutert werden sollen:

- (bspw. *Beispiel*): Für alle genannten Beispiele gilt die Anforderung auf jeden Fall. Weitere Anwendungsfälle müssen durch den Adressaten der Anforderung anwendungsfallbezogen ermittelt werden.
- (z. B. *Beispiel*): Die genannten Beispiele sind Möglichkeiten, um die Anforderung umzusetzen. Mindestens eine der genannten Möglichkeiten kann genutzt werden, um die Anforderung zu erfüllen. Weitere Alternativen können durch den Adressaten der Anforderung identifiziert und ergänzend oder alternativ verwendet werden.

3.1 Architektur

In dieser Rubrik werden zentrale Anforderungen definiert, die die grundlegende technische Architektur der UDP betreffen, komponentenübergreifend für die gesamte Plattform gültig sind oder zentrale Komponenten bzw. die Plattforminfrastruktur betreffen. Beim Einsatz von Container-Technologien und beim Betrieb der UDP auf Managed-Service-Infrastruktur gelten besondere Anforderungen, die jeweils in den entsprechenden Unterabschnitten dieses Kapitels dargestellt werden.

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
AR-1	Interne und externe Zugriffe auf Plattformkomponenten MÜSSEN mit den geringstmöglichen Privilegien erfolgen.	x	x	x	Betreiber, Entwickler
AR-2	Clientseitige Technologien mit bekannten Sicherheitsschwächen (bspw. NSAPI, Flash, ActiveX oder Java-Applets) DÜRFEN NICHT verwendet werden. Die Sicherheitseigenschaften clientseitiger Technologien SOLLEN dem Stand der Technik entsprechen.	x	x	x	Entwickler
AR-3	Nicht verwendete direkte Abhängigkeiten, nicht mehr benötigte Softwarekomponenten, Dateien und Dokumentationen MÜSSEN vom Produktivsystem entfernt werden.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
AR-4	Die Version aller Softwarekomponenten SOLL in den jeweiligen Build-Prozessen, sowie in Paketverwaltungen fixiert sein (Version Pinning).	x	x	x	Lösungsanbieter, Entwickler
AR-5	Alle durch die UDP erstellten Sitzungs-IDs (Session Identifier) MÜSSEN einzigartig und nicht erratbar sein (z. B. durch Verwendung von Level 4 UUIDs).	x	x	x	Betreiber, Lösungsanbieter, Entwickler
AR-6	Sitzungen (Sessions) MÜSSEN nach einem vorher definierten Zeitraum und nach Inaktivität ablaufen.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
AR-7	Die Benutzerverwaltung SOLL gruppen- oder rollenbasiert erfolgen. Jeder Benutzer SOLL mindestens einer definierten Gruppe oder Rolle zugewiesen sein.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
AR-8	Sicherheitsrelevante Informationen (insbesondere Information zu Gruppen- und Rollenzugehörigkeiten) MÜSSEN vor Manipulation und Replay-Angriffen (bspw. durch Verwendung von Zeitstempeln) geschützt sein.	x	x	x	Betreiber, Lösungsanbieter, Entwickler

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
AR-9	Alle verwendeten Schlüssel, PINs und Passwörter MÜSSEN (mit entsprechender Autorisierung) änderbar sein. Sofern verschlüsselte Daten gespeichert werden, MUSS es einen Prozess zum Schlüsselwechsel geben.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
AR-10	Durch Benutzer oder Clients bereitgestellte Geheimnisse (bspw. Passwörter, PINs, Schlüssel oder API-Tokens) MÜSSEN als unsicher betrachtet werden. Insbesondere DÜRFEN sie NICHT dafür verwendet werden, die Vertraulichkeit von Daten gegenüber Dritten sicherzustellen.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
AR-11	Alle verwendeten kryptographischen Verfahren SOLLEN gemäß TR-02102-1 ausgewählt und verwendet werden.	x	x	x	Lösungsanbieter, Entwickler
AR-12	Für sicherheitskritische Funktionen (bspw. Authentifizierung, Authentisierung, Autorisierung, Eingabevalidierung und Signaturprüfungen) SOLLEN etablierte und bewährte Standardfunktionen des verwendeten Frameworks, Betriebssystems oder der Programmiersprache genutzt werden.	x	x	x	Entwickler
AR-13	Bei der Validierung von Zertifikaten (z. B. für TLS-Verbindungen) MUSS stets die ganze Zertifikatskette sowie alle relevanten Attribute (bspw. Gültigkeitszeitraum und „Common Name“) geprüft werden. Bekannte „Revocation Lists“ MÜSSEN und OCSP-Responder SOLLEN berücksichtigt werden.	x	x	x	Entwickler
AR-14	Alle in der UDP verfügbaren Sicherheitsmechanismen SOLLEN standardmäßig aktiviert sein.	x	x	x	Betreiber, Lösungsanbieter
AR-15	Kommunikation zwischen Plattformkomponenten MUSS verschlüsselt, integritätsgeschützt und mindestens einseitig authentifiziert erfolgen (z. B. TLS).	x	x	x	Betreiber, Lösungsanbieter

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
AR-16	Plattformkomponenten in unterschiedlichen Vertrauenszonen MÜSSEN voneinander (z. B. durch Firewall-Regeln, API-Gateways, Reverse Proxies, Security-Gruppen oder ähnliche Mechanismen) isoliert sein.	x	x	x	Betreiber, Lösungsanbieter
AR-17	Für das Deployment von Softwarekomponenten MUSS ein authentifizierter und integritätsgeschützter Kanal verwendet werden. Die Integrität der Softwareartefakte selbst SOLL durch Signaturen sichergestellt werden.	x	x	x	Betreiber, Lösungsanbieter
AR-18	Systeme und Plattformkomponenten, deren Erreichbarkeit aus dem Internet nicht notwendig ist, MÜSSEN netzwerktechnisch vom Internet isoliert betrieben werden (z. B. durch Verwendung einer DMZ).	x	x	x	Betreiber
AR-19	Die UDP MUSS die Autorisierung für alle Plattformkomponenten über einen zentralen Dienst durchführen ⁵ . Das impliziert, dass dieser Dienst zur Autorisierung von allen durch Plattformkomponenten verarbeitete Anfragen genutzt wird. Insbesondere DÜRFEN Plattformkomponenten alternative Autorisierungsmechanismen NICHT anbieten. Einzige Ausnahme ist der Zugang für Infrastrukturadministratoren. Dieser SOLL über eine unabhängige Komponente authentifiziert und autorisiert werden ⁶ .		x	x	Betreiber, Lösungsanbieter
AR-20	Alle Web-basierten externen Schnittstellen MÜSSEN durch eine Web-Application-Firewall (WAF) geschützt werden.		x	x	Betreiber
AR-21	Die UDP MUSS einen Dienst zur zentralen Sammlung von Logging-Informationen verwenden.		x	x	Betreiber, Lösungsanbieter

⁵ Diese Anforderung schließt den verteilten Betrieb (z. B. aufgrund von notwendigen Verfügbarkeiten) explizit nicht aus

⁶ Ziel dieser Anforderung ist es zu verhindern, dass jede Komponente der UDP ihre eigene Benutzerverwaltung und Authentifizierungs- und Autorisierungsfunktionen verwendet und dadurch die Wahrscheinlichkeit für Fehler erhöht wird. Stattdessen soll die Autorisierung an einer zentralen Stelle durchgeführt werden. Diese Anforderung schließt somit explizit nicht die Verwendung von Anbietern für Single-Sign-On (SSO) zur Authentifizierung und Authentisierung aus, sofern die Autorisierung nach wie vor zentral durchgeführt wird.

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
AR-22	Softwarekomponenten von Drittanbietern MÜSSEN von offiziellen, authentifizierten Paketquellen bezogen werden. Die Integrität der Komponenten SOLL erfolgreich signaturbasiert validiert werden.		x	x	Betreiber, Lösungsanbieter, Entwickler
AR-23	Die fachliche Administration der Plattformkomponenten MUSS über eine Komponente realisiert werden, die ebenfalls den plattformeigenen Dienst zur Autorisierung verwendet. Insbesondere DÜRFEN komponenteneigene Administrationszugänge NICHT verwendet werden.		x	x	Betreiber, Lösungsanbieter, Entwickler
AR-24	Eine kontinuierliche Inventarisierung der Versionen sowohl von clientseitigen als auch von serverseitigen Softwarekomponenten (bspw. Frameworks, Bibliotheken) und deren Abhängigkeiten MUSS erstellt werden. Hierfür SOLLEN bekannte Werkzeuge (z. B. Versions, OWASP Dependency Check, retire.js oder andere bekannte Werkzeuge) verwendet werden.		x	x	Lösungsanbieter, Entwickler
AR-25	Für den Zugriff auf sensible Server-Systeme MUSS jeweils ein "Bastion Host" verwendet werden.		x	x	Betreiber
AR-26	Die Architektur der UDP MUSS so gestaltet sein, dass jegliche Kommunikation über externe Web-Schnittstellen über ein zentrales Gateway entgegengenommen wird ⁷ .			x	Betreiber, Lösungsanbieter
AR-27	Die Architektur der UDP MUSS so gestaltet sein, dass jegliche Kommunikation mit IoT-Geräten über ein zentrales Gateway entgegengenommen wird ⁷ .			x	Betreiber, Lösungsanbieter
AR-28	Die UDP MUSS eine Komponente verwenden, die automatisierte Auswertungen von Log-Informationen vornimmt und im Fall von auffälligen Sicherheitsereignissen Meldungen generiert.			x	Betreiber, Lösungsanbieter

⁷ Bei dieser Anforderung geht es darum, die Kontrolle über die Kommunikationsabläufe in der Architektur der UDP zu zentralisieren. Um zu verhindern, dass dadurch ein „Single Point of Failure“ entsteht, müssen ggf. weitere Maßnahmen zur Lastverteilung („Load Balancing“) getroffen werden.

ID	Anforderung	Level 1	Level 2	Level 3	Anwendbar für
AR-29	Die Administration der Infrastruktur MUSS über einen einzigen dedizierten Zugangsdienst erfolgen. Insbesondere DÜRFEN NICHT mehrere Zugangswege zur Administration der Infrastruktur existieren.			x	Betreiber
AR-30	Nicht verwendete Abhängigkeiten (inklusive transitiver bzw. indirekter Abhängigkeiten), MÜSSEN vom Produktivsystem entfernt werden.			x	Betreiber, Lösungsanbieter, Entwickler
AR-31	Kryptographisches Schlüsselmaterial SOLL in dafür speziell vorgesehenen Schlüsselspeichern oder Hardware-Sicherheitsmodulen (HSMs) gespeichert werden.			x	Betreiber, Lösungsanbieter, Entwickler
AR-32	Kritische Softwarekomponenten ⁸ MÜSSEN durch technische Maßnahmen (z. B. durch Sandboxing oder durch Container) isoliert laufen, und auch auf Netzwerkebene angemessen isoliert werden.			x	Betreiber, Lösungsanbieter

3.1.1 Container-Technologie

In dieser Rubrik werden Anforderungen an den Einsatz von Container-Technologien (bspw. Docker und Podman), an deren Orchestrierung (bspw. durch Kubernetes) sowie an deren Betrieb gestellt. Dadurch, dass in der Regel eine Vielzahl von Containern auf ein und demselben Host laufen, ergeben sich neue Herausforderungen in der Absicherung des Hosts selbst und den jeweiligen Containern, die über die klassische Härtung des Betriebssystems hinausgehen.

In den nachfolgenden Anforderungen werden die im Folgenden definierten Begriffe verwendet:

Orchestrator: Software, die verwendet wird, um die Bereitstellung, Verwaltung und Automatisierung von Containern in einem verteilten System zu koordinieren

Container-Image: eigenständige, ausführbare Einheit, die allen erforderlichen Code, Bibliotheken und Abhängigkeiten enthält, um eine Softwareanwendung auszuführen

Pods: laufende Instanz eines Container-Images

Namespace: Mechanismus mit dem Pods durch den Orchestrator logisch voneinander separiert werden

Master-Knoten: zentraler Dienst des Orchestrators, der die Steuerung, Verwaltung und Koordination von Ressourcen und Workloads übernimmt.

⁸ Als kritische Softwarekomponenten werden im Rahmen dieses Dokuments solche Softwarekomponenten bezeichnet, deren Kompromittierung ohne Überwindung weiterer Sicherheitsmechanismen die Kompromittierung der gesamten UDP zur Folge hat.

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
CT-1	Container-Images DÜRFEN NICHT mehr als den benötigten Anwendungscode und die benötigten Abhängigkeiten enthalten.	x	x	x	Lösungsanbieter, Entwickler
CT-2	Es SOLLEN Security-Werkzeuge (z. B. Clair, Trivy, Docker Security Scanning, etc.) verwendet werden, um Container-Images auf Sicherheitslücken zu prüfen.	x	x	x	Lösungsanbieter, Entwickler
CT-3	Es SOLLEN ausschließlich Basis-Images aus Quellen verwendet werden, die vom Hersteller bereitgestellt oder von ihm referenziert werden und für die regelmäßig und zeitnah Sicherheitsaktualisierungen zur Verfügung gestellt werden.	x	x	x	Lösungsanbieter, Entwickler
CT-4	Es SOLLEN minimalistische Basis-Images (z. B. Alpine Linux und Windows Nano Server) verwendet werden, um Angriffsflächen zu reduzieren.	x	x	x	Lösungsanbieter, Entwickler
CT-5	Geheimnisse MÜSSEN außerhalb von Container-Images gespeichert und zur Laufzeit dynamisch bereitgestellt werden.	x	x	x	Lösungsanbieter, Entwickler
CT-6	Das Host-Betriebssystem eines Container-Images DARF für die Realisierung der gewünschten Funktionalität unnötige Systemdienste (bspw. den Druckerwarteschlangendienst) NICHT ausführen.	x	x	x	Lösungsanbieter, Entwickler
CT-7	Es MÜSSEN angemessene Authentifizierungs- und Autorisierungsmechanismen implementiert werden, um den Zugriff auf den Orchestrator und seine Ressourcen zu steuern.	x	x	x	Betreiber
CT-8	Container-Images MÜSSEN so konfiguriert sein, dass sie mit den geringstmöglichen Privilegien betrieben werden können. Insbesondere DARF die Ausführung als „root“-Benutzer standardmäßig NICHT aktiviert sein.	x	x	x	Lösungsanbieter, Entwickler
CT-9	Für die Kommunikation zwischen Pods MUSS eine verschlüsselte und integritätsgeschützte Kommunikation (z. B. TLS) verwendet werden (vgl. auch AR-15).	x	x	x	Lösungsanbieter, Entwickler

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
CT-10	Es MÜSSEN jegliche Softwarewerkzeuge oder Bibliotheken entfernt werden, die nicht unbedingt benötigt werden (z. B. auch gängige wie „sed“ oder „awk“).		x	x	Lösungsanbieter, Entwickler
CT-11	Die Signatur jedes eingesetzten Images MUSS validiert werden, um sicherzustellen, dass die Images von vertrauenswürdigen Quellen stammen und nicht manipuliert wurden.		x	x	Lösungsanbieter, Entwickler
CT-12	Orchestratoren SOLLEN so konfiguriert sein, dass der Netzwerkverkehr in virtuelle Netzwerksegmente separiert wird.		x	x	Lösungsanbieter, Entwickler
CT-13	Orchestratoren SOLLEN den von Containern nach außen gesendeten Netzwerkverkehr kontrollieren. Diese Kontrollen SOLLEN mindestens an den Netzwerkgrenzen implementiert werden, um sicherzustellen, dass Pods keine unerwünschte Netzwerkkommunikation vornehmen.		x	x	Lösungsanbieter, Entwickler
CT-14	Container SOLLEN im „Read-Only-Modus“ für das Root-Dateisystem ausgeführt werden.		x	x	Lösungsanbieter, Entwickler
CT-15	Um den Datenverkehr zwischen verschiedenen Pods und Namespaces zu steuern, MÜSSEN Netzwerkrichtlinien implementiert werden. Dies hilft, unbefugten Zugriff zwischen Diensten zu verhindern und die Isolation zu verbessern.		x	x	Lösungsanbieter, Entwickler
CT-16	Sensible Informationen (bspw. API-Tokens, Passwörter und Zertifikate) MÜSSEN sicher verwaltet werden, vorzugsweise, indem dafür vorgesehener Speicher des Orchestrators (z. B. Kubernetes-Secrets) verwendet wird.		x	x	Lösungsanbieter, Entwickler
CT-17	Der Master-Knoten und die Konfigurationsoberfläche des Orchestrators DÜRFEN NICHT direkt aus dem Internet zugreifbar sein. Beispielsweise kann für den Remotezugriff eine VPN-Verbindung oder ein Bastion-Host verwendet werden.		x	x	Betreiber

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
CT-18	Ressourcengrenzen und Quotas SOLLEN eingesetzt werden, um Ressourcenerschöpfung und mögliche Denial-of-Service (DoS)-Angriffe zu verhindern.		x	x	Lösungsanbieter, Entwickler
CT-19	Fortgeschrittene Zugriffskontrolltechnologien (z. B. SELinux und AppArmor unter Linux oder Windows Defender Application Control und Windows Defender System Guard unter Windows) MÜSSEN verwendet werden, um eine verbesserte Kontrolle und Isolation für Pods, bereitzustellen.			x	Lösungsanbieter, Entwickler
CT-20	Für die Kommunikation zwischen Pods MUSS eine gegenseitige Authentifizierung (z. B. mTLS) verwendet werden.			x	Lösungsanbieter, Entwickler

3.1.2 Managed-Service

In dieser Rubrik werden Anforderungen an den Einsatz von Managed-Services gestellt. In Abgrenzung zu Anforderungen an die Architektur und Infrastruktur werden hier spezifische sicherheitsrelevante Aspekte adressiert, die nur den Managed-Service selbst betreffen. Beispiele hierfür sind die Auswahl eines sicheren Hypervisors, das Schlüsselmanagement sowie die sichere Konfiguration von Identitäts- und Zugriffsmanagement (Identity and Access Management – IAM).

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
MS-1	Für die Administration der Managed-Service-Infrastruktur (bspw. über Management-Konsolen) DÜRFEN sogenannte Root-Benutzer des anbieterspezifischen IAMs NICHT verwendet werden. Stattdessen MÜSSEN einzelne Benutzer für bestimmte Aufgaben mit eingeschränkten Rechten angelegt werden.	x	x	x	Betreiber
MS-2	Bei der Zuweisung von Rechten in dem anbieterspezifischen IAM MUSS das Prinzip der geringsten Privilegien (least privileges) eingesetzt werden.	x	x	x	Betreiber
MS-3	Fest programmierte Anmeldedaten oder Zugangsschlüssel für Zugriffe auf Dienste des Managed-Service-Anbieters DÜRFEN NICHT verwendet werden. Stattdessen MÜSSEN rollenbasierte temporäre Zugangsberechtigungen eingesetzt werden.	x	x	x	Betreiber, Lösungsanbieter

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
MS-4	Alle Schlüssel und Geheimnisse MÜSSEN in entsprechend dafür vorgesehenen Diensten des Managed-Service-Anbieters verwaltet werden.	x	x	x	Betreiber
MS-5	Virtual Private Clouds (VPCs) MÜSSEN so konfiguriert werden, dass Ressourcen logisch isoliert werden und die Kommunikation zwischen verschiedenen Teilen des Netzwerks gesteuert werden kann.	x	x	x	Betreiber
MS-6	Die vom Managed-Service-Anbieter bereitgestellten Netzzugangskontrolltechnologien (z. B. Security Groups) MÜSSEN eingesetzt werden, um den Netzverkehr auf einer höheren logischen Ebene zusätzlich zur IP-basierten Firewall zu beschränken.	x	x	x	Betreiber
MS-7	Eine Zugriffskontrolle für alle nicht-öffentlichen Dienste und Ressourcen (z. B. S3-Buckets) MUSS implementiert werden, um unautorisierte Zugriffe zu verhindern.	x	x	x	Betreiber
MS-8	Die automatische oder anderweitig softwarebasierte Interaktion mit durch den Managed-Service-Anbieter bereitgestellter Infrastruktur SOLL über speziell dafür erstellte API-Schlüssel erfolgen, deren Berechtigungen auf das absolut notwendige Maß eingeschränkt wurden. Insbesondere DÜRFEN Benutzer- oder Root-Accounts zu diesem Zweck NICHT verwendet werden.	x	x	x	Betreiber
MS-9	Es SOLLEN die vom Managed-Service-Anbieter bereitgestellten Sicherheitsdienste und Sicherheitswerkzeuge verwendet werden.		x	x	Betreiber
MS-10	Regelmäßige IAM-Audits MÜSSEN durchgeführt werden, um sicherzustellen, dass Privilegien von einer Rolle nicht auf eine andere Rolle übertragen werden können.		x	x	Betreiber
MS-11	Fortgeschrittene Sicherheitstechnologien (z. B. AMD SEV, Intel TDX oder ARM TrustZone) SOLLEN verwendet werden, um eine bessere Isolation von virtuellen Maschinen zu gewährleisten.			x	Betreiber

3.2 Authentifizierung und Autorisierung (AuthN/Z)

In dieser Rubrik werden die wesentlichen Anforderungen an eine sichere und zuverlässige Identitätsüberprüfung festgelegt. Die Einhaltung dieser Anforderungen an Authentifizierung und Autorisierung dient dem Aufbau eines robusten Schutzes vor unbefugtem Zugriff und verbessert so die allgemeine Sicherheitslage der UDP.

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
AUT-1	Die UDP MUSS einheitliche Vertrauensniveaus für alle Wege und Schnittstellen, über die Benutzer authentifiziert werden können, festlegen und anbieten. Insbesondere DARF es NICHT die Möglichkeit geben, auf ein schwächeres Authentisierungsverfahren zu wechseln.	x	x	x	Betreiber, Lösungsanbieter
AUT-2	Die UDP MUSS für alle passwortbasierten Benutzer-Authentisierungen Multi-Faktor-Authentisierung anbieten.	x	x	x	Lösungsanbieter, Entwickler
AUT-3	Für die Ausführung aller Softwarekomponenten und Dienste SOLLEN dedizierte Service-Accounts verwendet werden.	x	x	x	Betreiber, Lösungsanbieter
AUT-4	Für die Authentisierung, Authentifizierung und Autorisierung von Infrastrukturadministratoren MUSS ein Public-Key-basiertes Authentisierungsverfahren verwendet werden.	x	x	x	Betreiber, Lösungsanbieter,
AUT-5	Es MUSS ein Zugriffskontrollmodell definiert werden, das festlegt, welche Benutzer, Gruppen und Rollen Zugriff auf welche Daten haben. Das gilt auch für die Administration der Infrastruktur.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
AUT-6	Eine Anwendung MUSS es dem Nutzer ermöglichen, einen oder alle zuvor ausgestellten Sitzungs-IDs (Session Identifier) bzw. Authentisierungstokens zu invalidieren.	x	x	x	Betreiber, Lösungsanbieter, Entwickler

ID	Anforderung	Level 1	Level 2	Level 3	Anwendbar für
AUT-7	Bei einer Authentisierung mit einem Passwort MÜSSEN starke Passwortrichtlinien existieren. Dabei DÜRFEN 25 Zeichen mit geringer Komplexität (z. B. Passphrases) oder 8 Zeichen mit hoher Komplexität NICHT unterschritten werden. Informationen über die Stärke des gewählten Passworts DÜRFEN NICHT gespeichert werden.	x	x	x	Betreiber, Lösungsanbieter
AUT-8	Alle von der UDP angebotenen Multi-Faktor-Authentisierungsverfahren MÜSSEN Phishing-Resistent sein. ⁹		x	x	Entwickler, Lösungsanbieter
AUT-9	Für sensible Operationen (bspw. die Änderung der E-Mail-Adresse des Benutzerkontos oder des MFA-Verfahrens) MUSS eine erneute Authentisierung erzwungen werden.		x	x	Entwickler
AUT-10	Das Authentisierungsverfahren für Infrastrukturadministratoren MUSS mit Vertrauensniveau mindestens "substanziell" gemäß TR-03107 implementiert werden.		x	x	Betreiber, Lösungsanbieter
AUT-11	Für die Bewertung der Authentizität eines Authentisierungsvorgangs mittels Anomalie-Erkennung SOLLEN zusätzliche Informationen (z. B. das verwendete Endgerät, die verwendete IP-Adresse oder die Zeit des Zugriffs) mit einbezogen werden.		x	x	Betreiber, Lösungsanbieter, Entwickler
AUT-12	Die Kommunikation zwischen einzelnen Plattformkomponenten MUSS beidseitig authentifiziert erfolgen (z. B. durch mTLS).			x	Lösungsanbieter, Entwickler

3.3 Schnittstellen

3.3.1 Web-Anwendungen und Web-Schnittstellen

Diese Rubrik enthält Anforderungen an Web-Anwendungen und Web-Schnittstellen, die im Rahmen der UDP eingesetzt werden – sowohl für solche, die nur innerhalb dieser erreichbar sind und verwendet werden, als auch für solche, die offen im Internet betrieben werden.

Web-Anwendungen werden hier gesondert betrachtet, da hierfür eine Vielzahl von speziellen Bedrohungen und Angriffstechniken existieren, die jeweils berücksichtigt werden müssen.

⁹ https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/Studien/2FA/it-sicherheit.pdf?__blob=publicationFile&v=3_

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
W-1	Der Zugriff auf alle Ressourcen der UDP SOLL standardmäßig verweigert werden, außer für diejenigen, die als öffentliche Ressourcen vorgesehen sind.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
W-2	Es MUSS ein Zugriffskontrollmodell definiert werden, das festlegt, welche Benutzer, Gruppen und Rollen Zugriff auf welche Daten haben dürfen (vgl. AUT-5).	x	x	x	Entwickler
W-3	Das Zugriffskontrollmodell MUSS für alle Daten durch einen einheitlichen Zugriffskontrollmechanismus durchgesetzt werden.	x	x	x	Entwickler
W-4	Die Nutzung von Cross-Origin Resource Sharing (CORS) SOLL vermieden werden. Die Applikation SOLL eine dem Anwendungsfall entsprechend restriktive CORS-Policy implementieren.	x	x	x	Entwickler
W-5	Die Web-Server-Verzeichnisauflistung SOLL deaktiviert werden.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
W-6	Es MUSS sichergestellt werden, dass nicht benötigte Datei-Metadaten sowie Sicherungskopien aus dem Verzeichnis, das durch den Web-Server bereitgestellt wird, bereinigt werden.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
W-7	Sitzungs-IDs (Session Identifier) MÜSSEN nach dem Abmelden eines Benutzers auf dem Backend-System als ungültig markiert werden.	x	x	x	Entwickler, Lösungsanbieter
W-8	JSON-Web-Token (JWT) SOLLEN kurzlebig sein, um dieses Angriffsfenster zu minimieren.	x	x	x	Entwickler, Lösungsanbieter
W-9	Die Web-Anwendung MUSS für Datenverarbeitung und den Datenzugriff sichere Schnittstellen und Verfahren (z. B. Prepared Statements oder ORM für SQL-Abfragen) verwenden.	x	x	x	Entwickler
W-10	Die Verwendung von Funktionen, die Benutzereingaben automatisch in Codevariablen, interne Objekte oder Objekteigenschaften einbinden (Mass Assignment) SOLL vermieden werden.	x	x	x	Entwickler

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
W-11	Alle vom Client bereitgestellten Eingabewerte auf allen Feldern, Formularen und APIs MÜSSEN auf Seite des Clients validiert werden, um Systemmanipulationen und Fehler an der UDP zu verhindern.	x	x	x	Entwickler
W-12	Eine serverseitige Eingabevalidierung MUSS zusätzlich zur clientseitigen Eingabevalidierung verwendet werden, um Systemmanipulationen und Fehler an der UDP (bspw. durch Injektionsangriffe) zu verhindern.	x	x	x	Entwickler
W-13	Die Anzahl der Ergebnisse von Datenbankabfragen SOLL limitiert werden (z. B. durch das Schlüsselwort LIMIT in SQL), um im Falle von Injektionen die massenhafte Offenlegung von Datensätzen zu verhindern. Ebenso SOLLEN nur Datenbankspalten abgefragt werden, die von der Applikation auch verarbeitet werden.	x	x	x	Entwickler
W-14	Vorkonfigurierte Standardzugangsdaten MÜSSEN vor produktiver Nutzung einer Softwarekomponente geändert werden.	x	x	x	Lösungsanbieter, Entwickler
W-15	Bei der Deserialisierung von vom Client bereitgestellten Daten SOLLEN Whitelists verwendet werden, um die Objekte und Klassen zu beschränken, die aus den bereitgestellten Daten instanziiert werden können.	x	x	x	Entwickler
W-16	Das URL-Schema, die Adresse und der Port in den vom Client bereitgestellten URLs SOLL mithilfe einer Whitelist abgeglichen werden, um die Auswirkungen von Server-Side Requests Forgeries (SSRF) zu reduzieren.	x	x	x	Entwickler
W-17	Um Cross-Site-Request Forgery-Angriffe (CSRF-Angriffe) zu verhindern, SOLL der HTTP-Header „Allow-Origin“ mit einer Whitelist von bekannten Domains verwendet werden. ¹⁰	x	x	x	Betreiber, Lösungsanbieter, Entwickler

¹⁰ Eine offensichtlich begründete Ausnahme, die diese Anforderung nicht anwendbar macht („SOLL“), sind alle Schnittstellen, über die von einer Vielzahl von unbekannten Quellen zugegriffen wird (bspw. über Mobilapplikationen). Hier kann keine abschließende Whitelist aller bekannten Quellen angegeben werden, daher ist das Setzen des Allow-Origin-Headers in dieser Art nicht sinnvoll.

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
W-18	Detaillierte Fehlermeldungen aus Produktivsystemen DÜRFEN Benutzern NICHT angezeigt werden.	x	x	x	Entwickler, Betreiber
W-19	Detaillierte Informationen zu einem in der UDP eingesetzten Dienst, die für einen Angreifer hilfreich sein könnten (bspw. Versionsinformationen oder der Name des Dienstes) SOLLEN Benutzern NICHT angezeigt werden.	x	x	x	Entwickler, Betreiber
W-20	Die Verarbeitung aller nicht benötigten HTTP-Verben (z. B. PUT oder DELETE) MÜSSEN deaktiviert werden.	x	x	x	Entwickler
W-21	Sensible Daten MÜSSEN entweder im HTTP-Body oder in den HTTP-Headern übertragen werden. Insbesondere DÜRFEN sensible Daten NICHT Teil der URL sein.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
W-22	Bei allen Formularen, die vertrauliche Informationen enthalten können, SOLL die clientseitige Zwischenspeicherung deaktiviert werden, einschließlich der Funktionen zur automatischen Vervollständigung (bspw. bei JavaScript oder HTML5 das „autocomplete“ Attribute auf „off“ setzen).	x	x	x	Lösungsanbieter Entwickler
W-23	HTTP Strict Transport Security (HSTS) MUSS als zusätzlicher Schutzmechanismus für die Absicherung von HTTPS-Kommunikation aktiviert werden.	x	x	x	Betreiber, Lösungsanbieter Entwickler
W-24	Die Anzahl an Zugriffen pro Zeiteinheit auf APIs der Web-Anwendung MUSS limitiert werden (Rate Limiting).		x	x	Betreiber, Entwickler
W-25	Die Web-Anwendung SOLL die Anzahl der Parameter in einer Anfrage an den Web-Server minimieren, einschließlich versteckter Felder, Ajax-Variablen, Cookies und Header-Werte.		x	x	Lösungsanbieter Entwickler
W-26	Die UDP SOLL eine Prüfung auf schwache Passwörter (z. B. durch das Überprüfen neuer oder geänderter Passwörter anhand bekannter Passwortlisten) implementieren und die Verwendung dieser unterbinden.		x	x	Entwickler
W-27	Serialisierte Daten DÜRFEN nur nach vorheriger Integritätsprüfung verarbeitet werden, um Deserialisierungsangriffe zu vermeiden.		x	x	Entwickler

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
W-28	Serialisierte Daten SOLLEN durch Signaturen oder MACs vor Manipulation geschützt werden.		x	x	Entwickler
W-29	Ein Schema-basierter Antwortvalidierungsmechanismus SOLL als zusätzliche Sicherheitsebene implementiert werden. Als Teil dieses Mechanismus SOLLEN Daten, die von allen APIs zurückgegeben werden, vorab definiert werden. Weiter SOLL sichergestellt werden, dass Antworten nur die vorab definierten Daten enthalten.		x	x	Entwickler
W-30	Um Cross-Site-Scripting-Angriffe zu verhindern, MUSS eine sichere Content Security Policy (insbesondere ohne die Verwendung von „unsafe-inline“) implementiert werden.			x	Entwickler

3.3.2 IoT-Anbindungen

In dieser Rubrik werden Anforderungen an die sichere Nutzung von IoT-Geräten beschrieben. Fokus ist dabei insbesondere die sichere Anbindung der Geräte unter Verwendung von IoT-spezifischen Kommunikationsprotokollen. Explizit ausgenommen ist die sichere Entwicklung der IoT-Geräte selbst.

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
IoT-1	Der Zugang zu allen IoT-Ressourcen MUSS standardmäßig verweigert werden, es sei denn, es handelt sich um öffentliche Ressourcen.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
IoT-2	Das Zugriffskontrollmodell (vgl. AUT-5) MUSS für alle Daten durch einen einheitlichen Zugriffskontrollmechanismus durchgesetzt werden.	x	x	x	Entwickler
IoT-3	Es MUSS sichergestellt sein, dass nur authentifizierte und autorisierte IoT-Geräte Zugriff auf Daten der UDP erhalten.	x	x	x	Lösungsanbieter, Entwickler
IoT-4	Ein standardmäßig vorkonfigurierter globaler Verbindungsschlüssel (bspw. „ZigbeeAlliance09“) DARF NICHT verwendet werden.	x	x	x	Lösungsanbieter, Entwickler

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
IoT-5	Für die Autorisierung von neuen IoT-Geräten SOLL ein Pairing-Modus verwendet werden, der eine Benutzerinteraktion vorsieht. Das Pairing SOLL nach einer vordefinierten kurzen Zeitspanne automatisch beendet werden, auch wenn das Pairing nicht erfolgreich ist. Alternativ SOLLEN Geheimnisse für eine gegenseitige Authentifizierung auf den IoT-Geräten vorprovisioniert werden.	x	x	x	Lösungsanbieter, Entwickler
IoT-6	Netzschlüssel SOLLEN nach dem Zufallsprinzip generiert werden.	x	x	x	Lösungsanbieter, Betreiber
IoT-7	Netzschlüssel SOLLEN in regelmäßigen Abständen erneuert werden.	x	x	x	Lösungsanbieter, Entwickler
IoT-8	Die Kommunikation von IoT-Geräten mit der UDP MUSS vor Replay-Angriffen geschützt sein.	x	x	x	Lösungsanbieter, Entwickler
IoT-9	Jedes mit der UDP verbundene IoT-Gerät MUSS eindeutig identifiziert werden.	x	x	x	Lösungsanbieter, Entwickler
IoT-10	Kommunikationstechnologien mit bekannten Sicherheitsschwächen (bspw. Zigbee vor Version 3.0 und LoRaWAN vor Version 1.1 bzw. 1.0.3) DÜRFEN NICHT verwendet werden		x	x	Lösungsanbieter, Entwickler
IoT-11	Zur Authentisierung von IoT-Geräten SOLLEN PKI-Zertifikate verwendet werden.		x	x	Lösungsanbieter, Entwickler
IoT-12	Die Kommunikation zwischen IoT-Geräten und der UDP MUSS integritätsgeschützt erfolgen.		x	x	Betreiber, Lösungsanbieter, Entwickler
IoT-13	Die Kommunikation nicht-öffentlicher Daten zwischen IoT-Geräten und der UDP MUSS verschlüsselt erfolgen.		x	x	Betreiber, Lösungsanbieter, Entwickler

3.3.3 VPN-Zugang

In dieser Rubrik werden Anforderungen für die sichere Nutzung von VPN-Verbindungen aufgelistet. Der Fokus liegt dabei insbesondere auf dem sicheren Einsatz und dem sicheren Aufbau von Verbindungen über VPN.

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
VPN-1	Der VPN-Zugang MUSS so konfiguriert sein, dass Verschlüsselungsverfahren gemäß TR-02101-1 verwendet werden und die Verschlüsselung konsistent auf alle über die VPN-Verbindung übertragenen Daten angewendet wird.	x	x	x	Betreiber, Lösungsanbieter
VPN-2	Das VPN-Gateway, das als Einstiegspunkt für die VPN-Verbindung dient, MUSS sicher konfiguriert sein. Die Software des VPN-Gateways SOLL regelmäßig aktualisiert werden, um bekannte Sicherheitslücken zu schließen.	x	x	x	Betreiber, Lösungsanbieter
VPN-3	VPN-Zugriffskontrollen MÜSSEN durch rollenbasierte Autorisierungsrichtlinien und gruppenspezifische Einstellungen implementiert werden. Der Ressourcenzugriff SOLL anhand von Benutzerrollen (z. B. Mitarbeiter, Auftragnehmer und Infrastruktur-Administratoren) definiert werden und VPN-Gruppenrichtlinien SOLLEN für maßgeschneiderte Einstellungen und Zugriffskontrollen benutzt werden.		x	x	Betreiber, Lösungsanbieter
VPN-4	Die UDP MUSS Zugriffskontrolllisten (ACLs) verwenden, um Regeln darüber zu definieren und durchzusetzen, welcher Datenverkehr durch das VPN zugelassen oder abgelehnt wird. Diese können auf IP-Adressen, Protokollen und Ports basieren.		x	x	Betreiber, Lösungsanbieter
VPN-5	Alle Geräte, die sich mit dem VPN verbinden, MÜSSEN gemäß dem Stand der Technik und den geltenden IT-Sicherheitsorganisationsrichtlinien gesichert sein. Dazu SOLL insbesondere sichergestellt sein, dass nur aktualisierte Software genutzt wird und eine Endpoint-Protection-Lösung aktiviert ist.		x	x	Betreiber, Lösungsanbieter

3.4 Logging

In dieser Rubrik werden spezifische Anforderungen an die Protokollierung bzw. das Logging beschrieben. Die Anforderungen umfassen unter anderem Schlüsselaspekte wie Protokollformate, Datenaufbewahrung, Datenhandhabung und eine mögliche Integration mit einem SIEM-System (Security Information and Event Management).

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
L-1	Alle Komponenten und Dienste der UDP MÜSSEN Log-Informationen zu Sicherheitsereignissen erstellen.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
L-2	Logs von Sicherheitsereignissen MÜSSEN mindestens alle fehlgeschlagene Authentisierungsversuche und Autorisierungsvorgänge enthalten.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
L-3	Alle Log-Informationen MÜSSEN vor Manipulationen und vor unbefugtem Zugriff geschützt werden.	x	x	x	Betreiber, Lösungsanbieter
L-4	Sensible Daten (bspw. Passwörter oder Kreditkarteninformationen) DÜRFEN NICHT geloggt werden.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
L-5	Alle Komponenten und Dienste der UDP MÜSSEN Log-Informationen zu Sicherheitsereignissen in einem von der zentralen Logging-Plattformkomponente auswertbaren Format erstellen.		x	x	Betreiber, Lösungsanbieter
L-6	Der Zugriff auf vertrauliche Daten MUSS protokolliert werden.		x	x	Betreiber, Lösungsanbieter, Entwickler
L-7	Alle erstellten Log-Informationen MÜSSEN über einen transportgesicherten Kanal (z. B. TLS) auf einem zentralen Log-Server abgelegt werden.		x	x	Betreiber, Lösungsanbieter
L-8	Unberechtigte Zugriffsversuche auf Log-Dateien MÜSSEN erkannt werden können.		x	x	Betreiber
L-9	Eine automatisierte Verarbeitung von protokollierten Sicherheitsereignissen (z. B. mithilfe eines SIEM) und eine Erzeugung von Warnmeldungen MUSS implementiert werden.		x	x	Betreiber, Lösungsanbieter
L-10	Zugriffe über das VPN auf die UDP MÜSSEN protokolliert werden.		x	x	Betreiber, Lösungsanbieter

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
L-11	Der Datenverkehr der UDP MUSS auf Netzwerkebene überwacht und hinsichtlich Anomalien untersucht werden.		x	x	Betreiber

3.5 Datenhaltung

Diese Rubrik befasst sich mit den kritischen Aspekten und Sicherheitsanforderungen im Zusammenhang mit der sicheren Datenspeicherung. Diese sollen dazu beitragen, vertrauliche Informationen zu schützen, die Datenintegrität sicherzustellen und unbefugten Zugriff zu verhindern.

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
DH-1	Vertrauliche Daten MÜSSEN während der Speicherung (At-Rest) verschlüsselt sein – das gilt insbesondere auch für vertrauliche Daten, die in Backups gespeichert sind. Das Verschlüsselungsverfahren MUSS gemäß TR-02102-1 ausgewählt und verwendet werden.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
DH-2	Jeder geheime Schlüssel in der UDP MUSS vor unbefugtem Zugriff geschützt werden.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
DH-3	Schnittstellen zu Interprozesskommunikations-(IPC)-Mechanismen MÜSSEN durch Zugriffskontrollmechanismen vor unbefugtem Zugriff geschützt werden.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
DH-4	Es MUSS Vorgaben zur „Data Governance“ geben, durch die insbesondere der Lebenszyklus von in der UDP gespeicherten Daten vorgegeben wird.	x	x	x	Lösungsanbieter, Entwickler
DH-5	Zur Speicherung sensibler Daten (bspw. Benutzeranmeldeinformationen oder kryptografischer Schlüssel) SOLLEN dedizierte dafür vorgesehene Speicherfunktionen in der Hardware (z. B. TPMs) oder des Betriebssystems (z. B. Credential Manager unter Windows oder Keychain Services unter Linux) verwendet werden.		x	x	Betreiber, Lösungsanbieter, Entwickler

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
DH-6	Passwörter MÜSSEN mit Passwort-Hash-Funktionen wie „Argon2“ gehasht werden. Insbesondere DÜRFEN Hashfunktionen mit bekannten Schwachstellen und solche, die nicht explizit für das Hashen von Passwörtern entworfen wurden, (bspw. SHA3 oder MD5) NICHT verwendet werden.		x	x	Lösungsanbieter, Entwickler
DH-7	Vorgaben der „Data Governance“ SOLLEN durch technische Maßnahmen und automatisierte Prozesse durchgesetzt werden.		x	x	Lösungsanbieter, Entwickler
DH-8	Sensible Daten (bspw. kryptographisches Schlüsselmateriale) MÜSSEN unverzüglich aus dem Speicher entfernt werden, sobald sie nicht mehr benötigt werden. Für die Löschung SOLLEN dediziert dafür vorgesehene Funktionen des eingesetzten Betriebssystems oder Frameworks verwendet werden.		x	x	Betreiber, Lösungsanbieter, Entwickler
DH-9	Daten MÜSSEN vor der Speicherung dahingehend geprüft werden, ob Inhalt, Form und Struktur den Erwartungen entsprechen, um Injection-Angriffe zu erschweren.		x	x	Betreiber, Lösungsanbieter, Entwickler
DH-10	Es SOLL automatisierte Prozesse geben, die vertrauliche Daten nach Ablauf der definierten Aufbewahrungsfrist aus der Anwendung automatisch aus allen Plattformkomponenten entfernen.			x	Lösungsanbieter, Entwickler

3.6 IT-Sicherheitsorganisation

In dieser Rubrik werden Anforderungen an organisatorische Rahmenbedingungen für den sicheren Betrieb von IT-Infrastruktur gestellt.

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
ORG-1	Backups von Komponenten und Daten der UDP MÜSSEN regelmäßig erstellt werden. Backups auf Datenebene SOLLEN mindestens täglich durchgeführt werden.	x	x	x	Betreiber

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
ORG-2	Das Backup-System MUSS so konfiguriert sein, dass für das Löschen oder Überschreiben von bereits vorhandenen Backups besondere Privilegien notwendig sind. Insbesondere MUSS sichergestellt sein, dass die Standardberechtigungen zum Zugriff auf das Backup-System nicht dafür verwendet werden können, bestehende Backups zu modifizieren.	x	x	x	Betreiber
ORG-3	Wiederherstellungstests von Backups MÜSSEN regelmäßig durchgeführt werden.	x	x	x	Betreiber
ORG-4	Backups von Komponenten und Daten der UDP MÜSSEN zusätzlich an einem logisch oder netzwerktechnisch getrennten System angelegt werden, das unabhängig von der primären Datenspeicherung ist.	x	x	x	Betreiber
ORG-5	Der Zugriff auf jedes Backup-System und auf jeden Backup-Ort MUSS über ein individuell dafür eingerichtetes Benutzerkonto erfolgen. Insbesondere DARF der Zugriff auf unterschiedliche Backup-Systeme und Backup-Orte NICHT über ein und denselben Benutzer möglich sein.	x	x	x	Betreiber
ORG-6	Es MUSS ein Verfahren zur Verwaltung von Schwachstellen implementiert werden. Dazu MUSS insbesondere festgelegt werden, wie Informationen über bekannte Schwachstellen in Komponenten, die von der UDP eingesetzt werden, erfasst werden und wie auf diese Informationen in angemessener Zeit reagiert werden kann.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
ORG-7	Tests und Weiterentwicklungen der UDP DÜRFEN NICHT direkt auf Produktivumgebungen durchgeführt werden. Stattdessen MUSS es eine dedizierte Staging-Umgebung geben.	x	x	x	Betreiber, Lösungsanbieter, Entwickler
ORG-8	Die UDP SOLL regelmäßig Penetrationstests unterzogen werden.	x	x	x	Betreiber, Lösungsanbieter
ORG-9	Backups von Komponenten und Daten der UDP MÜSSEN zusätzlich an einem physisch getrennten Standort angelegt werden, der unabhängig von der primären Datenspeicherung ist.		x	x	Betreiber

<i>ID</i>	<i>Anforderung</i>	<i>Level 1</i>	<i>Level 2</i>	<i>Level 3</i>	<i>Anwendbar für</i>
ORG-10	Eine kontinuierliche Überwachung aller verwendeten Systeme, Anwendungen und Komponenten auf bekannte Schwachstellen und veraltete Versionen MUSS mithilfe automatischer Sicherheitsscanner durchgeführt werden.		x	x	Betreiber, Lösungsanbieter, Entwickler
ORG-11	Ein Verfahren zur Meldung von in der UDP identifizierten Schwachstellen MUSS veröffentlicht werden (z. B. im Rahmen von „Coordinated Vulnerability Disclosure“). Hierzu MUSS auch ein dedizierter Kontakt bekanntgegeben werden, um sicherzustellen, dass Schwachstellen sicher und vertraulich gemeldet werden können.		x	x	Betreiber, Lösungsanbieter
ORG-12	Ein Informationssicherheitsmanagementsystem (ISMS) SOLL gemäß ISO 27001 eingeführt und umgesetzt werden.		x	x	Betreiber
ORG-13	Ein Informationssicherheitsmanagementsystem (ISMS) SOLL gemäß ISO 27001 oder IT-Grundschutz des BSI zertifiziert werden.			x	Betreiber

4 Anwendungsbeispiel

Abbildung 2 zeigt ein Anwendungsbeispiel einer exemplarischen UDP. Ziel des Anwendungsbeispiels ist es darzustellen, wie die Architektur einer UDP gestaltet werden kann, um eine möglichst sichere Funktionsweise gewährleisten zu können. Anders als das generische Modell, zeigt das Anwendungsbeispiel nicht nur Bausteine, sondern auch einzelne Komponenten und Verbindungen zwischen diesen.

Das Anwendungsbeispiel verfügt über zentrale Dateneingangspunkte (Gateways), die alle eingehenden Anfragen an die Applikationsschicht der UDP entgegennehmen und an die passende Backend-Komponente verteilen. Die Verwaltung der Applikationsschicht (fachliche Administration) der UDP erfolgt über eine zentrale Management-Komponente, während die Administration der UDP-Infrastruktur über einen speziellen VPN-Zugang durchgeführt werden muss. Über einen zentralen Authentifizierungs- und Autorisierungsdienst (AuthN/Z) wird jede Kommunikation mit der Applikationsebene der UDP authentifiziert und autorisiert. Im Gegensatz dazu wird der Zugang für die Administration der Infrastruktur über das VPN separat authentifiziert (bspw. über Public Keys). Die Authentifizierung erfolgt unabhängig von dem zentralen Authentifizierungsdienst, da der Dienst selbst über diese Schnittstelle ebenfalls administriert werden soll. Das Anwendungsbeispiel enthält weiterhin eine Komponente zur Datenverarbeitung, die – je nach Anwendungsfall – jedoch vollständig optional sein kann. Die Datenhaltung ist stets in zwei Arten von Datenbanken separiert: eine zur Haltung von Betriebsdaten (wie etwa Datenbanktabellen von Applikationen, Authentifizierungsinformationen, etc.) und eine zur Haltung von Nutzdaten (wie etwa Sensordaten). Im Anwendungsbeispiel ist ebenfalls eine zentrale Komponente für Logging enthalten, die Performance- und Security-Logs aufzeichnen soll und diese an eine Komponente zur Überwachung („Monitoring“) übergibt.

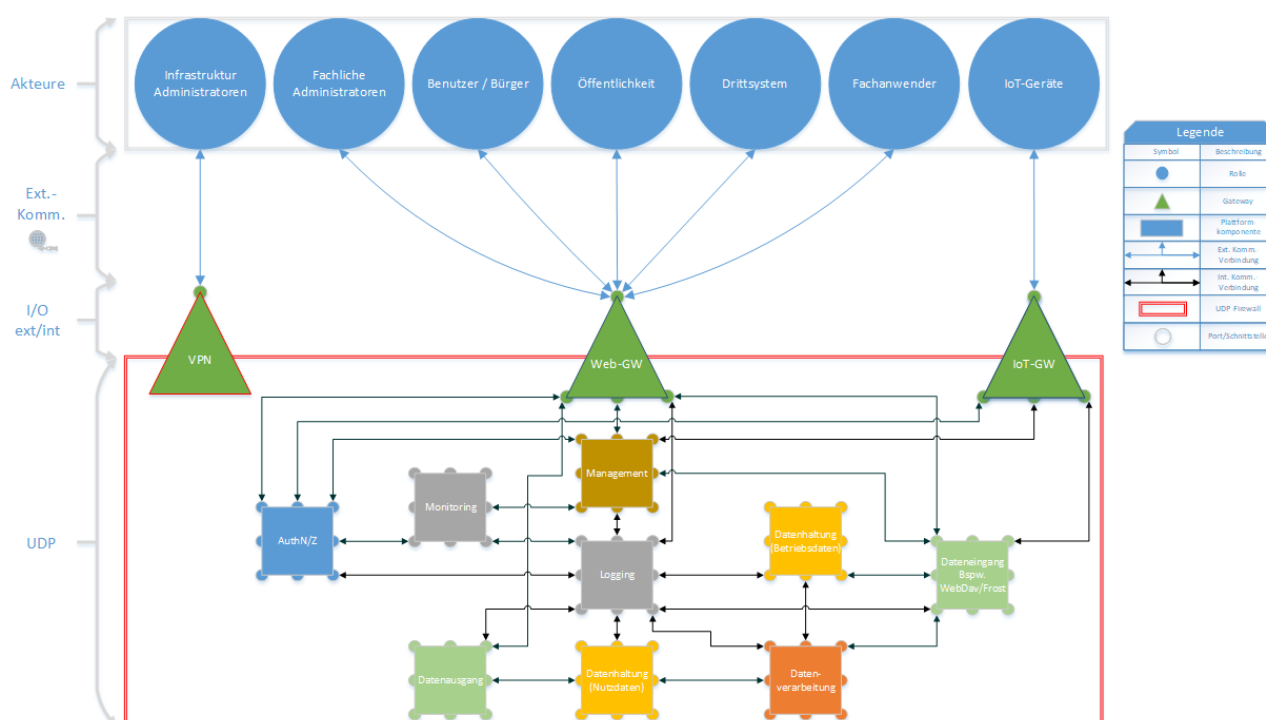


Abbildung 2: Anwendungsbeispiel einer exemplarischen UDP

Hier werden im Kontext dieses Beispiels relevante Akteure genannt und beschrieben.

- **Infrastruktur-Administratoren:** Haben als registrierte Nutzer administrativen Zugriff auf die VPN-Schnittstelle und können darüber die gesamte Infrastruktur administrieren.
- **Fachliche Administratoren:** Haben als registrierte Nutzer administrativen Zugriff auf die Management Komponente zur fachlichen Administration einer oder mehrerer Komponenten der UDP.
- **Benutzer/Bürger:** Können als registrierte Nutzer mit der UDP interagieren. Je nach Anwendungsfall können Sie Daten visualisieren, erstellen, hochladen, finden, freigeben und verwalten.
- **Öffentlichkeit:** Kann öffentlich bereitgestellte Daten abrufen, für die keine Authentifizierung notwendig ist.
- **Drittsysteme:** Können als registrierte Systeme mit der UDP interagieren. Die Datenverarbeitung erfolgt hier standardmäßig automatisiert. Dazu sind in der Regel andere Authentisierungsmechanismen (bspw. API-Keys) notwendig.
- **Fachanwender:** Können als registrierte Nutzer speziellere Analysen durchführen, für die spezifische Fachanwendungen implementiert werden.
- **IoT-Geräte:** Liefern als registrierte Geräte Messdaten an die UDP oder agieren als Aktoren.

4.1 Plattformkomponenten

- **Dateneingang:** Damit wird eine Backend-Komponente bezeichnet, die eingehende Nutzdaten entgegennimmt. In der Praxis ist es üblich für verschiedene Kommunikationsprotokolle jeweils eigene Backend-Dienste zu betreiben (bspw. FROST-Server zur Verarbeitung von REST-Anfragen und Chirpstack für IoT-Kommunikation), weswegen es in einer UDP mehrere Dateneingänge geben kann. Das Gateway wählt jeweils aus, welcher Dateneingang verwendet werden soll.
- **Management:** Über diese Komponente werden alle Management- und Konfigurationsaufgaben wahrgenommen, die die Applikationsschicht der UDP betreffen (bspw. das Hinzufügen von neuen IoT-Geräten, Änderung von Benutzerrechten, etc.). Die Schnittstelle ist an die zentrale Authentifizierungskomponente angebunden.
- **AuthN/Z:** Über diese Komponente wird Kommunikation (abgesehen von VPN) zentral authentifiziert und autorisiert, die die Applikationsschicht der UDP betrifft. Diese Komponente existiert aus Sicherheitsgründen nur einmal, selbst wenn die UDP zwischen einem Managed-Service und On-Prem aufgeteilt ist.
- **Datenhaltung (Betriebsdaten):** Hier werden alle Daten gespeichert, die für die reguläre Funktion aller Backend-Komponenten notwendig sind. Auch die Benutzerinformationen werden hier verwaltet.
- **Datenhaltung (Nutzdaten):** In dieser Komponente werden Nutzdaten der UDP gespeichert. Aufgrund der Tatsache, dass es sich hier in der Regel um große Datenmengen handelt, ist in der Praxis zur Realisierung (anders als bei Betriebsdaten) ggf. eine spezielle Datenbanktechnologie notwendig.
- **Datenverarbeitung:** Eine Komponente zur Realisierung von Datenveredelung (bspw. Analysen). Sie bekommt Daten aus der Dateneingangskomponente oder greift auf gespeicherte Daten in der Datenhaltung (Nutzdaten) zu.
- **Logging:** stellt eine zentrale Logging-Komponente in der UDP dar, in der alle anderen Komponenten ihre Logging-Daten aggregieren. Sie ist Teil des Logging-Bausteins des generischen Modells.
- **Monitoring:** Diese Komponente stellt basierend auf gespeicherten Log-Daten Auswertungen und ggf. Alarmer bereit (hier wird auch Security-Monitoring betrieben).

4.2 Externe Schnittstellen

In diesem Abschnitt werden die relevanten Schnittstellen einer UDP beschrieben.

- **IoT/Web-Gateway:** Diese Komponenten dienen als zentrale Sammelpunkte für alle Dateneingänge und -ausgänge, die die Applikationsschicht der UDP betreffen. Basierend auf dem Kommunikationsprotokoll (HTTP, MQTT, FTP, WebDAV, REST, etc.) entscheidet das jeweilige Gateway zu welchem Backend-Dienst (bspw. ein FROST-Server oder eine Chirpstack-Installation) die Anfrage weitergeleitet wird. Das Gateway bezieht dann den zentralen Authentifizierungsdienst mit ein. In diesem Fall werden anschließend auch Autorisierungsinformationen (bspw. ein Token) an den Backend-Dienst weitergeleitet.
- **VPN:** Über diese Komponente erfolgt die Administration der UDP-Infrastruktur (bspw. das Updaten von Diensten, Änderung von Konfigurationsdateien, etc.).

5 Abkürzungsverzeichnis

<i>Abkürzung</i>	<i>Begriff</i>
API	Application Programming Interface
ACL	Access Control List
BSI	Bundesamt für Sicherheit in der Informationstechnik
CORS	Cross Origin Resource Sharing
CSRF	Cross Site Request Forgery
DMZ	Demilitarisierte Zone
FTP	File Transfer Protocol
HSTS	HTTP Strict Transport Security
HTTP	Hypertext Transport Protocol
ISMS	Informationssicherheitsmanagementsystem
IAM	Identity and Access Management
IKT	Informations- und Kommunikationstechnologie
IoT	Internet of Things
IPC	Interprocess Communication
JWT	Json Web Token
MAC	Message Authentication Code
MFA	Multi-Faktor-Authentisierung
mTLS	Mutual Transport Layer Security
MQTT	Message Queuing Telemetry Transport
OWASP	Open Worldwide Application Security Project
ORM	Object Relation Model
OCI	Open Container Initiative
REST	Representational State Transfer
SIEM	Security Information and Event Management
SOAP	Simple Object Access Protocol
SQL	Structured Query Language
TLS	Transport Layer Security
TPM	Trusted Platform Module
UUID	Universally Unique Identifier
UDP	Urbane Datenplattform oder Urban Data Platform
WAF	Web Application Firewall
VPN	Virtual Private Network